



ANSI/CAN/UL 2900-1:2023

JOINT CANADA-UNITED STATES
NATIONAL STANDARD

STANDARD FOR SAFETY

Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements



ANSI/UL 2900-1-2023



SCC FOREWORD

National Standard of Canada

A National Standard of Canada is a standard developed by a Standards Council of Canada (SCC) accredited Standards Development Organization, in compliance with requirements and guidance set out by SCC. More information on National Standards of Canada can be found www.scc.ca.

SCC is a Crown corporation within the portfolio of Innovation, Science and Economic Development (ISED) Canada. With the goal of enhancing Canada's economic competitiveness and social well-being, SCC leads and facilitates the development and use of national and international standards. SCC also coordinates Canadian participation in standards development, and identifies strategies to advance Canadian standardization efforts.

Accreditation services are provided by SCC to various customers, including product certifiers, testing laboratories, and standards development organizations. A list of SCC programs and accredited bodies is publicly available at www.scc.ca.

Document Was Downloaded By Marco Stucchi For Use By ABB INC Stucchi, Marco : 5/4/2026 - 5:35 AM

UL Standard for Safety for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements, ANSI/CAN/UL 2900-1

Second Edition, Dated December 13, 2023

Summary of Topics

This Second Edition of ANSI/CAN/UL 2900-1, dated December 13, 2023, incorporates editorial changes including renumbering and reformatting to align with current style.

All rights reserved. No part of this publication may be reproduced, stored in a retrieval system, or transmitted in any form by any means, electronic, mechanical photocopying, recording, or otherwise without prior permission of ULSE Inc. (ULSE).

ULSE provides this Standard "as is" without warranty of any kind, either expressed or implied, including but not limited to, the implied warranties of merchantability or fitness for any purpose.

In no event will ULSE be liable for any special, incidental, consequential, indirect or similar damages, including loss of profits, lost savings, loss of data, or any other damages arising out of the use of or the inability to use this Standard, even if ULSE or an authorized ULSE representative has been advised of the possibility of such damage. In no event shall ULSE's liability for any damage ever exceed the price paid for this Standard, regardless of the form of the claim.

Users of the electronic versions of UL's Standards for Safety agree to defend, indemnify, and hold ULSE harmless from and against any loss, expense, liability, damage, claim, or judgment (including reasonable attorney's fees) resulting from any error or deviation introduced while purchaser is storing an electronic Standard on the purchaser's computer system.

No Text on This Page

Document Was Downloaded By Marco Stucchi For Use By ABB INC Stucchi, Marco : 5/4/2026 - 5:35 AM



ANSI/UL 2900-1-2023

DECEMBER 13, 2023



1

ANSI/CAN/UL 2900-1:2023

Standard for Software Cybersecurity for Network-Connectable Products,

Part 1: General Requirements

First Edition July, 2017

Second Edition

December 13, 2023

This ANSI/UL Standard for Safety consists of the Second Edition.

The most recent designation of ANSI/UL 2900-1 as an American National Standard (ANSI) occurred on April 14, 2023. ANSI approval for a standard does not include the Cover Page, Transmittal Pages, Title Page, Preface or SCC Foreword.

This standard has been designated as a National Standard of Canada (NSC) on April 14, 2023.

COPYRIGHT © 2023 ULSE INC.

Document Was Downloaded By Marco Stucchi For Use By ABB INC Stucchi, Marco : 5/4/2026 - 5:35 AM

No Text on This Page

Document Was Downloaded By Marco Stucchi For Use By ABB INC Stucchi, Marco : 5/4/2026 - 5:35 AM

CONTENTS

Preface	5
---------------	---

INTRODUCTION

1 Scope	9
2 Normative References	9
3 Glossary	10
4 Documentation Of Product, Product Design And Product Use	14
5 Product Design Documentation	15
6 Documentation for Product Use	15
7 Risk Controls	16
7.1 General	16
8 Access Control, User Authentication and User Authorization	16
9 Remote Communication	18
10 Sensitive Data	18
11 Product Management	18

RISK MANAGEMENT

12 Vendor Product Risk Management Process	19
---	----

SOFTWARE COMPOSITION

13 Software Composition Analysis	21
14 Malware Testing	21
15 Malformed Input Testing	21
16 Structured Penetration Testing	23

SOFTWARE WEAKNESSES

17 Software Weakness Analysis	23
-------------------------------------	----

SOFTWARE VULNERABILITIES

18 Static Binary and Bytecode Analysis	24
--	----

ANNEX A (INFORMATIVE)

A1 Sources for Software Weaknesses	25
A2 Weaknesses and Vulnerabilities	25

ANNEX B (INFORMATIVE)

B1 Requirements for Secure Mechanisms for Storing Sensitive Data and Personally Identifiable Information	27
--	----

ANNEX C (INFORMATIVE)

C1 Requirements for Security Functions	28
--	----

ANNEX D (INFORMATIVE)

No Text on This Page

Document Was Downloaded By Marco Stucchi For Use By ABB INC Stucchi, Marco : 5/4/2026 - 5:35 AM

Preface

This is the Second Edition of the ANSI/CAN/UL 2900-1, Standard for Software Cybersecurity for Network-Connectable Products, Part 1: General Requirements.

ULSE Inc. is accredited by the American National Standards Institute (ANSI) and the Standards Council of Canada (SCC) as a Standards Development Organization (SDO).

This Standard has been developed in compliance with the requirements of ANSI and SCC for accreditation of a Standards Development Organization.

This ANSI/CAN/UL 2900-1 Standard is under continuous maintenance, whereby each revision is approved in compliance with the requirements of ANSI and SCC for accreditation of a Standards Development Organization. In the event that no revisions are issued for a period of four years from the date of publication, action to revise, reaffirm, or withdraw the standard shall be initiated.

In Canada, there are two official languages, English and French. All safety warnings must be in French and English. Attention is drawn to the possibility that some Canadian authorities may require additional markings and/or installation instructions to be in both official languages.

Only metric SI units of measurement are used in this Standard. If a value for measurement is followed by a value in other units in parentheses, the second value may be approximate. The first stated value is the requirement.

Annexes [A](#), [B](#), [C](#), and [D](#), identified as informative, are for guidance and informational purposes only.

Comments or proposals for revisions on any part of the Standard may be submitted to ULSE at any time. Proposals should be submitted via a Proposal Request in ULSE's Collaborative Standards Development System (CSDS) at <http://csds.ul.com>.

Our Standards for Safety are copyrighted by ULSE Inc. Neither a printed nor electronic copy of a Standard should be altered in any way. All of our Standards and all copyrights, ownerships, and rights regarding those Standards shall remain the sole and exclusive property of ULSE Inc.

This Edition of the Standard has been formally approved by the Technical Committee (TC) on Software Cybersecurity for Network-Connectable Products: General Requirements, TC 2900-1.

This list represents the TC 2900-1 membership when the final text in this standard was balloted. Since that time, changes in the membership may have occurred.

TC 2900-1 Membership

Name	Representing	Interest Category	Region
Ahmadi, Mike	M Ahmadi	General	USA
Alvarez, Edison	Becton Dickinson	Producer	USA
Barker, Davis	Stanley Black & Decker	Producer	USA
Biggs, Douglas	UL Solutions	Testing & Stds Org	USA
Chevalier, Mathieu	Genetec	Producer	Quebec, Canada
Cosman, Eric	OIT Concepts LLC	Non voting member	USA
Datko, Joshua	Cryptotronics	General	USA
Dawson, Joe	EWA-Canada (an Intertek Co)	Testing & Stds Org	Newfoundland, Canada
Deskurakis, John	Carrier	Producer	USA
Dischert, Larry	Johnson Controls, Inc./Building Solutions North America	Commercial / Industrial User	USA
Dutta, Ashim	Eaton India Innovation Center	Producer	India
Fitzgerald, Brian	Food & Drug Administration	Government	USA
Fogleman, Greg	Department of Veterans Affairs	Government	USA
Garrett, Michael	Garrett Technologies Inc	General	USA
Garvy, Patrick	Honeywell	Producer	USA
Gatz, Stephen	Whirlpool Corp.	Producer	USA
Griffith, Steve	NEMA	Non-voting member	USA
Hicken, Arthur	PARASOFT	Testing & Stds Org	USA
Hornberger, Richard	Phoenix Contact Services Inc	Commercial / Industrial User	USA
Lee, Simon	U S Consumer Product Safety Commission	Non-voting member	USA
Leinonen, Juuso	ECRI	Supply Chain	USA
Li, Xiaodong	Lenovo (Beijing) Ltd	Producer	China
Martin, Robert	The Mitre Corporation	Commercial / Industrial User	USA
Maxey, Derek	Lockheed Martin Missiles & Fire Control	Supply Chain	USA
Mendoza, Ernesto	Signify North America Corporation	Producer	USA
Prince, Deborah R.	UL Standards & Engagement	TC Chair – Non-voting	USA
Rowland, Michael	IAEA	Government	Austria
Shkolnik, Moti	Firedome	Supply Chain	USA
Thayer, Rodney	Smithee Solutions LLC	General	USA
Tran, Phat	BC Safety Authority	Non-voting member	British Columbia, Canada
Treuthardt, Caroline	UL Standards & Engagement	TC Project Manager – Non-voting	USA
Vasserman, Eugene	Kansas State University	General	USA
Wang, Hui	CNCERT/CC	General	China
Wyman, Richard	CS 7 CONSULTING	General	USA

International Classification for Standards (ICS): 35.030, 35.110, 35.240.50

For information on ULSE Standards, visit <https://www.shopulstandards.com>, call toll free 1-888-853-3503 or email us at ClientService@shopULStandards.com.

ULSE INC. COPYRIGHTED MATERIAL – NOT AUTHORIZED FOR FURTHER REPRODUCTION OR DISTRIBUTION WITHOUT PERMISSION FROM ULSE INC.

This Standard is intended to be used for conformity assessment.

The intended primary application of this standard is stated in its scope. It is important to note that it remains the responsibility of the user of the standard to judge its suitability for this particular application.

CETTE NORME NATIONALE DU CANADA EST DISPONIBLE EN VERSIONS FRANÇAISE ET
ANGLAISE

No Text on This Page

Document Was Downloaded By Marco Stucchi For Use By ABB INC Stucchi, Marco : 5/4/2026 - 5:35 AM

INTRODUCTION

1 Scope

1.1 This standard applies to network-connectable products that shall be evaluated and tested for vulnerabilities, software weaknesses and malware.

1.2 This standard describes:

- a) Requirements regarding the software developer (vendor or other supply chain member) **risk management process** for their product.
- b) **Methods by which a product shall be evaluated and tested** for the presence of vulnerabilities, software weaknesses and malware.
- c) Requirements regarding the presence of **security risk controls in the architecture and design** of a product.

1.3 This standard **does not contain** requirements regarding **functional testing of a product**. This means this standard contains no requirements to verify that the product functions as designed.

1.4 **This standard does not contain requirements regarding the hardware** contained in a product.

2 Normative References

2.1 All references are for the latest published version of the document, unless stated otherwise.

[1] IEEE 1149, *Standard for Test Access Port and Boundary-Scan Architecture*

[2] ITU-T X.1520, *Cybersecurity information exchange – Vulnerability/state exchange – Common vulnerabilities and exposures (CVE)*;
retrievable from <https://cve.mitre.org/>

[3] ITU-T X.1521, *Cybersecurity information exchange – Vulnerability/state exchange – Common vulnerability scoring system (CVSS)*;
retrievable from <https://nvd.nist.gov/vuln-metrics/cvss>

[4] ITU-T X.1524, *Cybersecurity information exchange – Vulnerability/state exchange – Common weakness enumeration (CWE)*

[5] ITU-T X.1525, *Cybersecurity information exchange – Vulnerability/state exchange – Common weakness scoring system (CWSS)*;
retrievable from <https://cwe.mitre.org/cwss>

[6] ITU-T X.1544, *Cybersecurity information exchange – Event/incident/heuristics exchange – Common attack pattern enumeration and classification (CAPEC)*;
retrievable from <https://capec.mitre.org>

[7] Common Weakness Risk Analysis Framework (CWRAF);
retrievable from <https://cwe.mitre.org/cwraf/>

[8] CWE/SANS Top 25 Most Dangerous Software Errors;
retrievable from cwe.mitre.org/top25

[9] CWE On the Cusp: other weaknesses to consider;
retrievable from <https://cwe.mitre.org/top25/cusp.html>

[10] OWASP Top 10; latest version retrievable from https://www.owasp.org/index.php/Top_10_2013-Top_10

[11] ISO/IEC 11889, *Information technology – Trusted platform module library*

[12] ISO/IEC 9796, (all parts), *Information technology – Security techniques – Digital signature scheme giving message recovery*

[13] ISO/IEC 9797, (all parts), *Information technology – Security techniques – Message Authentication Codes (MACs)*

[14] ISO/IEC 9798 (all parts), *Information technology – Security techniques – Entity authentication*

[15] ISO/IEC 10118 (all parts), *Information technology – Security techniques – Hash-functions*

[16] ISO/IEC 11770 (all parts), *Information technology – Security techniques – Key management*

[17] ISO/IEC 14888 (all parts), *Information technology – Security techniques – Digital signatures with appendix*

[18] ISO/IEC 15946 (all parts), *Information technology – Security techniques – Cryptographic techniques based on elliptic curves*

[19] ISO/IEC 18033 (all parts), *Information technology – Security techniques – Encryption algorithms*

[20] ISO/IEC 19772 (all parts), *Information technology – Security techniques – Authenticated encryption*

[21] NIST, *The National Institute of Standards and Technology Cybersecurity Framework*

[22] NIST SP 800-140C, *Annex A: Approved Security Functions*

[23] NIST SP 800-140D, *Annex D: Approved Key Establishment Techniques*

[24] NIST 800-53, *The National Institute of Standards and Technology Special Publication*

[25] NIST SP 800-88, *Guidelines for Media Sanitization*

[26] NIST SP 800-122, *Guide to Protecting the Confidentiality of Personally Identifiable Information*

[27] FIPS 186-4, *Federal Information Processing Standards – Digital Signature Standard (DSS)*

3 Glossary

3.1 ATTACK – The use of one or more exploit(s) by an adversary to achieve one or more negative technical impact(s).

3.2 ATTACK PATTERN – A description of a generic method for carrying out attacks.

3.3 AUTHENTICATION – The process of verifying the identity of an entity.

3.4 AUTHENTICITY – The property that data, information or software originate from a specific entity.

3.5 AUTHORIZATION – The process of giving an entity permission to access or manipulate the product, or the property that an entity has such permission.

3.6 BINARY CODE – Machine instructions and/or data in a format intended for a specific processor architecture.

3.7 BYTECODE – Instructions and/or data that are created from source code as an intermediate step before generating binary code. Bytecode is independent of a specific processor architecture and is typically handled by a virtual machine or interpreter.

3.8 COMMON ATTACK PATTERN ENUMERATION AND CLASSIFICATION (CAPEC) – Specified in ITU-T X.1544 (ref. [6]), the CAPEC is a publicly available resource providing a list and classification of a large number of attack mechanisms based on the topology of the environment.

3.9 COMMON VULNERABILITIES AND EXPOSURES (CVE) – Specified in ITU-T X.1520 (ref. [2]), the CVE is a publicly available resource providing common identifiers for known vulnerabilities and exposures.

3.10 COMMON VULNERABILITY SCORING SYSTEM (CVSS) – Specified in ITU-T X.1521 (ref. [3]), the CVSS is a publicly available resource providing a means for prioritizing vulnerabilities in terms of exploit potential.

3.11 COMMON WEAKNESS ENUMERATION (CWE) – Specified in ITU-T X.1524 (ref. [4]), the CWE is a publicly available resource providing a structured means to exchange unified, measurable sets of information providing common identifiers for software weaknesses, as well as consequences, detection methods and examples of each weakness.

3.12 COMMON WEAKNESS SCORING SYSTEM (CWSS) – Specified in ITU-T X.1525 (ref [5]), the CWSS is a publicly available resource providing a means for prioritizing CWEs based on their technical impact, ease of attack, and other factors.

3.13 COMMUNICATION PROTOCOL – A system of rules regarding syntax, semantics, synchronization and error recovery of data communication, allowing two or more entities to exchange information.

3.14 CONFIDENTIALITY – The property that data, information or software is not made available or disclosed to unauthorized individuals, entities, or processes.

3.15 CREDENTIALS – A set of attributes that uniquely identifies a system entity such as a person, an organization, a service, a role, or a device.

3.16 EXECUTABLE – A file containing instructions in binary code, which can be used by a computer to perform computational tasks.

3.17 EXPLOIT – An input or action designed to take advantage of a weakness (or multiple weaknesses) and achieve a negative technical impact.

NOTE: The existence of an exploit targeting a weakness is what makes that weakness a vulnerability.

3.18 EXTERNAL INTERFACE – An interface of the product that is designed to potentially allow access to an entity outside the product; for example user interfaces, remote interfaces, local interfaces, wireless interfaces and file inputs.

3.19 **GENERATIONAL MALFORMED INPUT TESTING** – A method of deriving malformed input test cases by using detailed knowledge of the syntax and semantics of the specifications of the protocol or file format being tested.

3.20 **HARM** – Physical injury or damage to the health of people, or damage to property or the environment.

3.21 **I2C BUS** – An inter-integrated circuit bus.

3.22 **INTEGRITY** – The assurance that data can only be altered by authorized entities.

3.23 **JTAG** – Joint Test Action Group (JTAG) method of connection described in IEEE 1149, Standard for Test Access Port and Boundary-Scan Architecture.

3.24 **KNOWN VULNERABILITY** – A vulnerability described in the National Vulnerability Database (NVD).

NOTE: The NVD is accessible at <https://nvd.nist.gov>.

3.25 **LIBRARY** – A software set of code, functions, classes, procedures, scripts, configuration data that can be used by an executable.

3.26 **MALFORMED INPUT TESTING** – A black-box testing technique used to reveal software weaknesses in a product by triggering them with invalid or unexpected inputs on the external interfaces of the product.

3.27 **MALFORMED INPUT TEST CASE** – The basic unit of malformed input testing, which consists of a single interaction with the product under test.

3.28 **MALWARE** – Software designed with malicious intent to disrupt normal function, gather sensitive information, and/or access other connected systems.

3.29 **NETWORK CONNECTABLE** – Any device, component, or software that can be connected via physical, wireless, cellular, and other non-physical transmission means to another device, component or software or groups of devices, components or systems of software.

3.30 **PENETRATION TESTING** – A mechanism of evaluation of a product to exploit vulnerabilities and weaknesses discovered in the vulnerability assessment phase.

3.31 **PERSONALLY IDENTIFIABLE INFORMATION (PII)** – Any information about an individual maintained by the product, including any information that can be used to distinguish or trace an individual's identity, such as name, social security number, date and place of birth, or biometric records;

AND

Any other information that is linked or linkable to an individual, such as medical, educational, financial, and employment information.

NOTE: This can be, but is not limited to an individual's location, health records and/or financial records that when used can determine the actual individual's identity.

3.32 **PRODUCT** – The network-connectable device, software or system under test.

3.33 PROTOCOL – See COMMUNICATION PROTOCOL, [3.13](#)

3.34 REMOTE INTERFACE – An external interface potentially allowing access to individuals, entities or processes regardless of geographic distance to the product.

3.35 REMOTE ACCESS – Access to the product via a remote interface.

3.36 RISK – The potential for harm or damage, measured as the combination of the likelihood of occurrence of that harm or damage and the impact of that harm or damage.

3.37 RISK ANALYSIS – The systematic use of available information to identify threats and to estimate risk.

3.38 RISK CONTROL – Any action taken or feature implemented to reduce risk.

3.39 RISK MANAGEMENT – Systematic application of management policies, procedures and practices to the tasks of analyzing, evaluating, controlling and monitoring risk.

3.40 SECURE ELEMENT – A tamper-resistant platform like a chip capable of securely hosting applications and their confidential and cryptographic data and that will prevent unauthorized access.

3.41 SECURITY – The process of having acceptable levels of confidentiality, integrity, authenticity and/or availability of product data and/or functionality through risk analysis.

3.42 SENSITIVE DATA – Sensitive data is any critical security parameter that can compromise the use and security of the product such as passwords, keys, seeds for random number generators, authentication data., personally identifiable information and any data whose disclosure could jeopardize the security properties of the product.

3.43 SOFTWARE – All pre-loaded data which creates, affects, and/or modifies the functionality of the product. This includes, but is not limited to, firmware, scripts, initialization files, pre-compiled code and interpreted code. This does not include software preloaded and programmed in an IC chip for small functions that require physical access and removal of the IC chip for reprogramming.

3.44 SOFTWARE BILL OF MATERIALS (SBOM) – A nested inventory, a list of ingredients that make up software components.

3.45 SOFTWARE WEAKNESS – A possible flaw in the architecture, design, coding, build process or configuration of software in the product that may render the product vulnerable to a security exploit.

3.46 SOURCE CODE – Computer instructions written in a human-readable high-level computer language, usually as text, including possible comments.

3.47 SPI – is a serial peripheral shared interface bus.

3.48 STATIC ANALYSIS – A process in which source code, bytecode or binary code is analyzed without executing the code.

3.49 TEMPLATE MALFORMED INPUT TESTING – Generates test cases by introducing anomalies into a valid message or file. Template malformed input test cases are not protocol aware and therefore will not contain items such as correct checksums and valid session IDs.

3.50 **THREAT** – A potentially successful attack, utilizing specific techniques and resources to take advantage of specific vulnerabilities or lack of risk controls within a product.

3.51 **TRUSTED PLATFORM MODULE** – Defines the requirements for a dedicated microprocessor with requirements for storage of cryptographic keys used to secure physical products and the software contained.

3.52 **USER** – A person or process using a product or accessing it over one of its external interfaces.

3.53 **VENDOR** – The manufacturer, reseller or supplier of a product, that takes final responsibility for the cybersecurity of that product towards the purchaser and/or user and which submits that product for testing according to this standard.

3.54 **VULNERABILITY** – A weakness identified in the product for which an exploit does exist, such that it can be directly used by an attacker.

3.55 **WIRELESS INTERFACE** – An external interface using electromagnetic waves, rather than some form of wire, to carry communication signals to and from a product.

4 Documentation Of Product, Product Design And Product Use

4.1 The vendor shall provide the following for a product evaluation:

- a) A description of all functions (such as operational features, security, management functions, and the like), provided by the product;
- b) A list of all external interfaces of the product in its intended configuration, along with all communication protocols supported on each of these interfaces, where applicable, including:
 - 1) All remote interfaces;
 - 2) All local interfaces – product local interfaces such as SPI, I2C, JTAG and serial ports;
 - 3) All wireless interfaces;
 - 4) All external file inputs;

NOTE: Supported means capable of being enabled.

c) A list of all executables and libraries in the product, including all third party and open-source software. All executables and libraries shall be identified by both a software name and version number. Known operating system executables and libraries can be defined as the stated distribution of that operating system but any additional operating system libraries not defined in the known distribution shall be identified.

NOTE: An equivalent software bill of materials (SBOM) i.e a list of the contents of the software can be substituted.

d) The existing source code of all software in the product that is available including the scripts, libraries, makefiles, and build configuration parameters necessary to replicate the production build environment shall be provided as needed per the section Software Weakness.

NOTE: The specified materials are intended to allow an evaluator to establish and configure the product so it can be deployed and function correctly in its intended use environment. This requirement does not preclude developers from also providing representative pre-built, pre-configured products for testing purposes.

e) The binary code and/or bytecode and associated identifiers of all software in the product, unless the vendor has no access or no rights to this binary or bytecode as in a third-party library that is controlled. A risk management assessment of a controlled third-party library that the vendor has no

access or rights to shall be required. The binary code and/or bytecode provided shall be unobfuscated when available.

NOTE: An associated identifier such as a hash or signature or SWID tags that can validate the contents and functionality of the binary and/or bytecode.

f) Detailed instructions on the product software build and integration process.

g) A clear definition of the boundary between the product and elements of the system that are outside the scope of evaluation. See 6.8.

NOTE: If the objective is to do a sub-component or a system within a system, the boundary between the products in and out of scope need to be well defined.

h) Any run-time configuration files required for the operation of the product and constituent software under evaluation.

NOTE: When applying this standard, it is intended that a product boundary be identified that includes all product components utilized to meet applicable UL 2900-1 requirements.

5 Product Design Documentation

5.1 The vendor shall provide the following for a product evaluation:

a) The security risk analysis for the product as described in 12.1 of this standard.

b) The design documentation containing sufficient details to allow an evaluation of the way each of the risk controls mentioned in Sections 7 – 11 is implemented in the product.

6 Documentation for Product Use

6.1 Product use documentation supports the overall cyber security objectives through the product life cycle.

NOTE: Other organizations have written various good practices manuals. The National Institute of Standards and Technology Cybersecurity Framework, and the National Institute of Standards and Technology Special Publication 800-53 series are two examples.

6.2 The vendor shall provide documentation addressing security considerations on the intended use of the product and its configuration.

6.3 The vendor shall provide documentation addressing the environment in which the product is intended to be used.

6.4 The vendor shall provide instructions to ensure the effectiveness of security functions and controls during product use.

6.5 The vendor shall document all external interfaces and all communication protocols used externally by the product, including which external interfaces support which protocols.

6.6 The vendor shall provide documentation of all version numbers of all software binaries, libraries and executables used in the product. Known operating system executables and libraries can be defined as the stated distribution of that operating system but any additional operating system libraries not defined in the known distribution shall be identified.

6.7 The vendor shall provide documentation listing security-related event descriptions, logged by the product according to 11.3 and 11.4.

6.8 The vendor shall provide documentation of requirements and recommendations on the product's configuration and the environment in which the product is installed that are necessary to ensure the product's security.

NOTE: This should include requirements on network security, physical access control to the product, firewall ports and protocols, local interfaces' configuration options etc.

6.9 The vendor shall provide documentation that the product's authentication and authorization methods and subsequent authenticated and authorized communications cannot be bypassed using any procedure that uses less computation than exercising all elements of the set of values necessary for systematic deduction of the authentication's secret value(s).

6.10 Any overrides to 6.9 shall be evaluated and documented in the risk assessment with a rationale.

NOTE 1: For example, if a key is used for authentication, then it should require at least as many operations to circumvent the authentication means as it does to guess the credential.

NOTE 2: This requirement is intended to define disclosure requirements stating the difficulty of bypassing, brute-forcing, or otherwise circumventing the authentication system of the product.

NOTE 3: If authenticated communications is not physically or cryptographically secure, then 6.9 cannot be met.

7 Risk Controls

7.1 General

7.1.1 The product (or the product's vendor, as applicable) shall comply with all of the security risk controls specified in Sections 8 – 11, unless the risk assessment performed by the vendor according to Section 12, Vendor Product Risk Management Process, shows that the risks associated with not implementing a specific control are acceptable in product use.

7.1.2 If the vendor chooses to not comply with one or more of these risk controls, the vendor shall document and justify this in the risk analysis per 12.1.

7.1.3 Any time sensitive functionality shall be evaluated and documented in the risk assessment with a rationale.

7.1.4 Functionality that relies on time keeping and/or time synchronization shall be evaluated in the risk assessment with a rationale.

7.1.5 Product use cases or updates to the product that have the potential to change the security risk, shall be evaluated and included in the risk analysis.

8 Access Control, User Authentication and User Authorization

8.1 Product operation or management functions which may affect or alter the security of the product as defined by the vendor documentation shall require authentication and authorization prior to access of the product need to be documented as per Section 12, Vendor Product Risk Management Process.

8.2 Authentication services to the product shall implement an inactivity time-out or other appropriate mechanism to prevent perpetual authorization. The inactivity time-out interval shall be configurable at a user level or by the product's response to an event or action.

8.3 If the product uses an authentication credential mechanism for authenticating users:

- a) The product shall use a cryptographically secure mechanism complying with the requirements in Annex B to store and transmit the credential.
- b) Authentication error messages provided by the product shall not allow for enumerating valid credentials.
- c) The product shall support the possibility to set requirements regarding the, complexity, update frequency, strength or length for credentials with the following rules:
 - i) If the credential uses a password, its minimum length shall be 6 characters.
 - ii) For every 10 sequential unsuccessful authentication attempts of a user, operator or process within the product over a one-hour period, the credential shall either be disabled or a timeout of a minimum of 30 minutes shall be applied before another authentication attempt is allowed.
 - iii) If i) or ii) are not met, the required minimum length, frequency and strength of the credential shall be evaluated and documented in the risk assessment. Some alternatives that can be utilized are an increasing delay for each unsuccessful attempt and anti-robot protection such as captcha tests.

NOTE: A complexity test can also be run. Complexity options can include special characters, minimum length, upper and lowercase and combinations of options and/or key sizes.

- d) The product shall protect against brute force attacks.

NOTE: Examples of mechanisms to do so include key stretching; salts or preventing login attempts for the given credential after a specified number of failed attempts and/or dictionary attacks and/or rainbow table use.

- e) The product shall have no default credential that cannot be modified or supplanted by an alternative (like a user defined credential that replaces a built-in factory default). All default credentials should have a mechanism for change upon first use after installation with a user notification of Default Credentials in use if applicable.
- f) The product shall have an option to limit the number of unsuccessful attempts.

8.4 For products using a role-based access mechanism:

- a) The vendor shall clearly document all existing roles and their associated privileges.
- b) There shall be an 'administrator' or 'system' role that has privileges exclusively related to the management of the product. Such privileges shall not be granted to other roles.

NOTE: Other roles are to be assigned using the principle of least privilege.

8.5 The product shall support the possibility to manage the list of valid user accounts by adding, removing and/or suspending user accounts (e.g. "allow-listing" and "block-listing") or by adding, revoking, or updating of authentication credentials.

8.6 The product shall support assigning privileges and permissions to roles and credentials.

8.7 The product shall enforce the principle of least privilege for every authorized role or user that can be authenticated.

8.8 When an authenticated session is terminated, the product shall ensure the renewed session is authenticated prior to allowing access. Stored data from the previous session shall not be used to simplify/ease/partially bypass authentication mechanisms during a new session creation.

NOTE: The session is the protected communication once authentication has occurred. Protected means compliant with the Standard.

8.9 If the product uses other mechanisms for authentication besides username and password, the mechanism shall be such that the product's authentication method cannot be bypassed using any procedure that uses less computation than exercising all elements of the set of values necessary for systematic deduction of the authentication's secret value(s).

NOTE 1: For example, if a key is used for authentication, then it shall require at least as many operations to circumvent the key as it is to determine the key.

NOTE 2: This requirement is intended to address the difficulty of bypassing, brute-forcing, or otherwise circumventing the authentication system of the product.

9 Remote Communication

9.1 The product shall ensure the integrity and authenticity of all data communicated over any remote interface. For this, the product shall use security functions complying with the requirements in Annex C.

Exception: Remote interfaces that report status, do not provide command and control functionality or do not transmit sensitive data, etc., may not require integrity and authenticity but will need to be documented as per Section 12, Vendor Product Risk Management Process.

NOTE: Remote interface describes interaction points outside the defined boundaries of the product subject to the requirements of this standard.

10 Sensitive Data

10.1 The product shall ensure the confidentiality of all sensitive and personally identifiable data information generated, stored, used, or communicated by the product. The product shall use a secure mechanism complying with the requirements in Annex B to store the sensitive data and personally identifiable information.

10.2 For the purposes of 10.1, the vendor shall identify and document which data is to be considered sensitive.

10.3 The product shall utilize only cryptographic algorithms listed in Annex C for any security protocol.

10.4 The product shall use a separate cryptographic key for each service, operation, or function (e.g. data at rest encryption, transport layer encryption, operator role authentication, remote software upgrade image integrity). The vendor shall clearly document the intended purpose of each key used by the product. Rationale shall be documented in accordance with Vendor Product Risk Management Process, Section 12.

NOTE: Purposes may include (but are not limited to) data encryption, providing data authenticity and integrity, key wrapping, random number generation or digital signatures.

11 Product Management

11.1 The product shall be designed and implemented to allow for application of security updates to the product's software. This process will also support reverting to previously installed version if the update fails. The roll back would revert to the previously installed version.

11.2 The product shall verify the authenticity and integrity of any software update cryptographically, before installing the update. Product updates shall be possible in an offline environment. This offline product update mode should also still support validation of authenticity and integrity.

11.3 The product shall be capable of maintaining one or more log(s) of all security-related events, such as successful and unsuccessful login attempts, change of user authentication credentials, changes in the list of valid user accounts, successful and unsuccessful software updates, etc.

11.4 Unless and until they are transmitted to an external data storage, the product shall store all security-related logs in non-volatile memory and shall not allow non-privileged users to remove or change them.

11.5 Decommissioning of the product after its use shall allow the ability to completely erase all user defined:

- a) Configuration data;
- b) Sensitive data; and
- c) Personally identifiable information.

NOTE: NIST SP 800-88 may be used as a reference. As an example, zeroing the data is acceptable. Removal of data from the product can be performed as an operation or as a process procedure.

11.6 The following are approved integrity mechanisms for software updates. Validating software updates OR software source using the following techniques:

- a) A message authentication code generated on the software and firmware binaries, executables and libraries.
- b) A digital signature applied to the software and firmware components.
- c) A hash applied to the software and firmware binaries, executables, and libraries, where the hash is published in such a way that it is possible for the product to securely identify the source of the software and its contents.

11.7 All integrity mechanisms defined in 11.6 shall comply with Annex C.

11.8 Documentation shall exist describing the plan for providing validated software updates and patches as needed throughout the lifecycle of the product to continue to assure its continued security management.

RISK MANAGEMENT

12 Vendor Product Risk Management Process

12.1 When designing the product, the vendor shall establish and document a security risk analysis for the product, containing:

- a) An identification of all product functionalities and all sensitive data stored, processed or used by the product;
- b) A list of identified threats for the product, its functionalities and data;
- c) An assessment of the impact of each identified threat, its operational impact and any or sensitive data that would be exposed, should it become a reality;

- d) An assessment of the likelihood of each identified threat based on the vendor's assumptions;
- e) A determination of the resulting vendor defined risk level for each threat, considering its impact and likelihood;
- f) Risk management criteria, (i.e. clear criteria to determine whether or not a given vendor defined risk level is acceptable);
- g) A determination of suitable risk controls to mitigate each identified threat with an unacceptable risk level. All risk controls in Sections 7 – 11 shall be considered. The vendor shall identify any additional risk controls that need to be implemented to mitigate identified threats. The vendor shall create a traceability matrix showing the relationship between identified threats and implemented risk controls.
- h) An assessment of the residual risk level for each identified threat after application of these risk controls.

12.2 When carrying out the threat analysis resulting in the list meant in 12.1(b), the vendor shall make use of a classification scheme for risks identified. Some common examples that may be used are:

- a) The Common Attack Pattern Enumeration and Classification, (CAPEC; see ref. [6]) in order to convey the completeness of the analysis;
- b) DREAD model of Damage, Reproducibility, Exploitability, Affected users, Discoverability;
- c) Equivalent Risk classification methodology.

12.3 The vendor shall document a risk evaluation method for the possible presence of known (types of) vulnerabilities in the product. This method shall describe the criteria that the vendor will use to evaluate the level of risk for each (type of) known vulnerabilities that may be found in product. The method shall also establish the level below which a risk is acceptable to the vendor. The evaluation criteria shall be based on risk factors including, but not limited to, the CVSS score of the vulnerability, the intended use of the product and the environment in which the product would be used. If the vendor has allowed for the presence of any known vulnerabilities in the product, the vendor's security risk analysis for the product shall contain a description of each accepted known vulnerability:

- a) CVE standard vulnerability identifier;
- b) The software location of the vulnerability;
- c) A risk analysis, performed and documented according to the method and criteria, documented by the vendor as their risk evaluation method for known vulnerabilities in the product, showing that the risk level associated to the presence of this vulnerability is acceptable.

12.4 The vendor shall likewise document a risk evaluation method for the possible presence of known (types of) software weaknesses in the product. This method shall describe the criteria that the vendor will use to evaluate the level of risk for each (type of) software weakness that may be found in product. The vendor shall make use of the Common Weakness Risk Analysis Framework (CWRAF), ref. [7], or comparable, as part of a strategy of risk management. The method shall also establish the level below which a risk is acceptable to the vendor. The evaluation criteria shall be based on risk factors including, but not limited to, the CWSS score of the weakness, the intended use of the product and the environment in which the product would be used. In case the vendor is aware of and has accepted the presence of any software weaknesses in the product, the vendor's security risk analysis for the product shall contain a description of each accepted weakness:

- a) CWE standard weakness identifier;

- b) The software location of the weakness;
- c) A risk analysis, performed and documented according to the vendor's documented risk evaluation method for known vulnerabilities in the product, showing that the risk level associated with the presence of this weakness is acceptable;
- d) External compensating controls to help further reduce the residual risk.

12.5 To verify compliance with 12.1 – 12.3 and 12.4, the security risk analysis for the product shall be evaluated along with the product design documentation. In particular, the following shall be determined:

- a) Sufficient coverage during the security risk analysis with regard to the identification of product functionality and data and threats, impact, likelihood and resulting risk.
- b) Sufficient adoption of risk controls listed in Sections 7 – 11 by either implementing each control in the product or justifying why the risk level of not implementing a control is acceptable.
- c) Sufficient implementation of risk controls per the requirements in Sections 7 – 11.

NOTE: Sufficiency is established via analysis of traceability through the risk management process.

12.6 To verify compliance with 12.3 and 12.4, the vendor's risk evaluation methods for the presence of known vulnerabilities and software weaknesses shall be evaluated.

SOFTWARE COMPOSITION

13 Software Composition Analysis

13.1 The vendor shall decompose the software system to the level required to perform an analysis of weaknesses and vulnerabilities in accordance with Sections 17 and 18 below.

NOTE: This process may also be known as Software Composition Analysis. Information produced from this can be used to build a software bill of materials (SBOM).

14 Malware Testing

14.1 The binary code and bytecode in the product shall be scanned by at least one malware detection tool to identify if any known malware exists in the final deliverables of the product. The malware tools shall be applicable to the operating system that the software resides on.

14.2 To verify compliance with 14.1, all available binary code and bytecode provided by the vendor shall be inspected for known malware.

Exception: If a malware detection tool is not available for the applicable operating system, a risk assessment shall be conducted and documented per Section 12.

15 Malformed Input Testing

15.1 The product shall continue to operate as intended when subject to invalid or unexpected inputs on its external interfaces and shall not display unexpected behavior, such as, but not limited to the following:

- a) The product resets or reinitializes its configuration;
- b) A process hangs;

- c) The testing uses resources of the product and the product does not relinquish these resources after testing;
- d) The product software throws an unhandled exception;
- e) A storage data corruption occurs;
- f) The product loses the connection to the malformed input testing tool;
- g) The specified behavior of the product is interrupted and the product does not continue to operate as intended within 2 minutes or a timeframe defined by the manufacturer;
- h) The product shall not disclose any personally identifiable information or sensitive data over any interface enumerated in 4.1(b).
- i) The product shall not become non-responsive on external interfaces other than the one under test by the input testing tool.

15.2 To verify compliance with 15.1, malformed input testing shall be performed on the product as described in this section.

15.3 During malformed input testing, the product shall be configured per vendor documentation provided per 6.1 and 6.6.

15.4 Malformed input testing shall take place within a representative environment per vendor documentation provided per 6.1 and 6.6.

15.5 The product shall be inspected to verify the presence of those and only those external interfaces specified in the vendor's documentation per 4.1(b).

15.6 The product shall be subjected to malformed input testing of all file inputs, all remote interfaces, using all protocols supported by the product on these interfaces as listed by the vendor per 4.1(b). Each protocol on an interface shall be subjected to generational malformed input testing when available. Template malformed input testing may be used if a protocol is proprietary and there are no generational malformed input tools available for that protocol.

15.7 If generational malformed input testing is used for a protocol, testing shall evenly apply to all fields of the protocol and the testing shall implement exception handling based on the context of the protocol.

NOTE: Exception handling includes checks on message lengths, message identifiers, integrity checks, correct use of cryptographic protocols and other critical protocol attributes.

15.8 If template malformed input testing is used for a protocol on an interface, the template used shall cover all fields of the protocol.

15.9 If generational malformed input testing is applied for a protocol on an interface, at least 1,000,000 unique and independent test cases or a minimum of 8 hours of test case execution shall be carried out, whichever comes first.

15.10 If template malformed input testing is applied on an interface, at least 5,000,000 unique and independent test cases or a minimum of 8 hours of test case execution shall be carried out, whichever comes first.

15.11 If a protocol semantic structure space is substantially smaller than the limits set in 15.9 and 15.10 because of the lack of uniqueness or time to completion, the vendor shall supply the maximum range of unique cases and timeframe for execution to be used.

16 Structured Penetration Testing

16.1 The product under test shall have no known vulnerabilities known to the vendor that can be exploited and/or cause the product to crash, degrade, or perform in the manner not consistent with designed functionality without a recovery to its previous state after the test is completed in 2 minutes or within a timeframe defined by the manufacturer. The initial configuration shall be set up per the following:

- a) To verify compliance with 16.1, penetration testing shall be carried out on the product as described in this section.
- b) During penetration testing the product shall be configured per vendor documentation provided per 6.1 and 6.6.
- c) Penetration testing shall take place within a representative environment per documentation provided per 6.1, 6.6, and 6.8.

16.2 The product shall be subjected to the penetration testing in order to try to find and exploit any flaws in the product based on the following conditions:

- a) Circumvent the risk controls and security configuration of the product;
- b) Attempt to engage the product in a denial of service;
- c) Attempt to access and authenticate on the product via unauthorized means;
- d) Attempt to exploit vulnerabilities acceptable in the risk analysis;
- e) Attempt to elevate privilege on the product.

16.3 Attempts shall be made to identify system, application and service information via scanning of the ports, interfaces and services. Use of that information shall be considered in attempts to circumvent the security measures of the product. Exploit tools and scripts shall be used for discovered information to attempt to access the product, elevate the privilege once accessed or to gain further information about the product.

16.4 All risk assessment items scored in the risk assessment as not addressed shall be assessed with attempts to exploit to validate the risk assessment per Section 16, Structured Penetration Testing.

SOFTWARE WEAKNESSES

17 Software Weakness Analysis

17.1 The product or system under test shall contain no known software weaknesses that are unacceptable per Section 12.

NOTE 1: Typically, identified weaknesses must be eliminated from the product. However, in some cases, weaknesses can be shown to have a low enough risk that they can be acceptable. Paragraph 12.4 identifies the elements and actions required by the produced developer to determine if a weakness is acceptable. Any weaknesses that are identified as unaddressed will be tested through structured penetration testing (16.4) to verify they cannot be exploited.

NOTE 2: See A2 for information on weaknesses and vulnerabilities.

17.2 To verify compliance with 17.1, the product shall be evaluated using static source code analysis, and static binary and bytecode analysis as described in Sections 17 and 18. The testing should be conducted using the latest version of the sources mentioned in Annex A, as a guide and as applicable to the product under testing.

NOTE: Organizations interested in a list of known high risk software weaknesses may consider ISO/IEC 5055:2021, MISRA C++:2008, or MISRA C:2012.

17.3 Static source code analysis shall be performed as follows:

- a) All source code provided per 4.1(d) shall be evaluated by means of static code analysis;
- b) The product shall be evaluated for at least all software weaknesses listed in the latest versions of the sources mentioned in Annex A, as applicable to the product;
- c) Selection of the tool should be determined by the strategy determined in 12.4.

SOFTWARE VULNERABILITIES

18 Static Binary and Bytecode Analysis

18.1 All binary and/or bytecode provided by the vendor per 4.1(e) shall be evaluated by means of static analysis. Where static analysis of the binary and/or bytecode cannot be performed, it shall be evaluated per Section 12.

18.2 The product shall be evaluated for software vulnerabilities.

18.3 Selection of the tool should be determined by the strategy determined in 12.4.

18.4 The binary code and bytecode under test, per 4.1(e), shall contain no known vulnerabilities, unless acceptable per 12.3.

NOTE: Typically, known vulnerabilities must be eliminated from the product. However, in some cases, vulnerabilities can be shown to have a low enough risk that they can be acceptable. Paragraph 12.3 identifies the elements and actions required by the product developer to determine if a vulnerability is acceptable. Accepted vulnerabilities and mitigations identified in the Risk Assessment are considered during structured penetration testing [16.2(d)] to verify they cannot be exploited.

18.5 To verify compliance with 18.4, all available binary code and bytecode provided by the vendor shall be evaluated for all known vulnerabilities applicable to the product published in the National Vulnerability Database (NVD) at the time of evaluation.

NOTE: The NVD is currently accessible at <https://nvd.nist.gov>.

ANNEX A (INFORMATIVE)

A1 Sources for Software Weaknesses

- a) CWE/SANS Top 25 Most Dangerous Software Errors, ref. [8];
- b) CWE/SANS on the cusp list, ref. [9];
- c) OWASP Top 10, ref. [10].

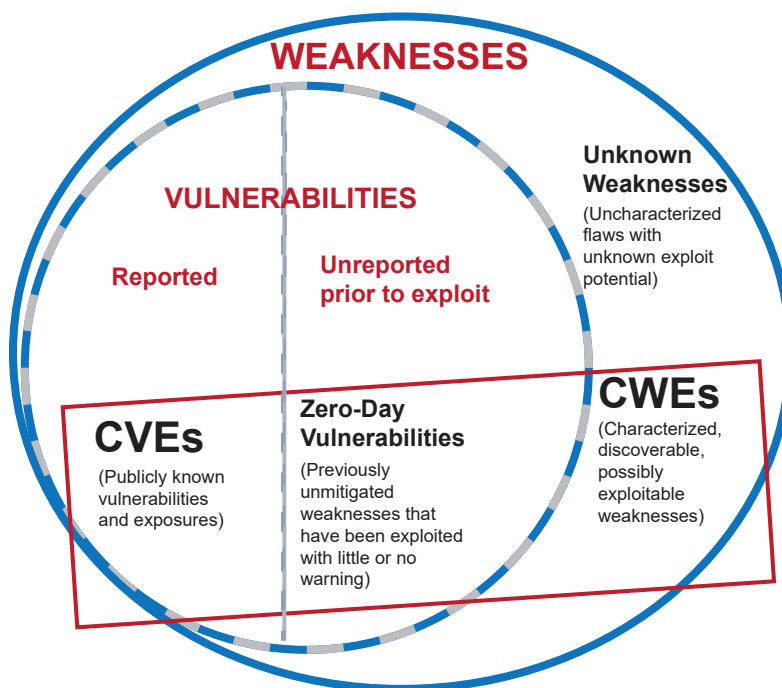
A2 Weaknesses and Vulnerabilities

The separation of weaknesses and vulnerabilities, as illustrated in the [Figure A1](#) below, may be useful to organizations that are responsible for the pre- and post-market management of vulnerabilities. These three categories of cybersecurity risk should be considered throughout the lifecycle of a product and can be more effectively coupled with tools like threat models if there is standardization in component nomenclature through processes such as the Common Platform Enumeration (CPE) format, since this could enable the level of abstraction of a threat model to facilitate rapid integration of newly published vulnerabilities into that model.

Once a weakness or vulnerability is appropriately localized and associated with a specific component in the threat model, analysts could then have a much more efficient and effective way to determine whether a given vulnerability is, in fact, an exposure in that particular application context. Ideally, this would also be consistent with how software components are identified in the organization's SBOM(s), so that tools like the SBOM and threat model are complementary and better support full lifecycle vulnerability management.

They may also wish to leverage standardized sources like the National Vulnerability Database (NVD) when including information relating to Common Vulnerabilities and Exposures (CVEs) to identify known or emerging vulnerabilities. Similarly, when describing their own in-house-developed or first-party custom software in their threat model, organizations may wish to consider standardizing in the same ways, so that Common Weakness Enumerations (CWEs) can be readily associated with the organization's custom software components and also be readily mapped into the threat model and regularly surveilled as potential targets for exploitation, which, if exploited, could also more quickly evolve into CVEs and be transitioned from generic CWE listings like SANS Top 25, SANS on the Cusp, OWASP Top 10 lists, etc., into specific known vulnerabilities and exposures that enter repositories like the NVD, leveraging processes such as Coordinated Vulnerability Disclosure (CVD).

Figure A1
Weaknesses and Vulnerabilities



su4668

ANNEX B (INFORMATIVE)

B1 Requirements for Secure Mechanisms for Storing Sensitive Data and Personally Identifiable Information

B1.1 Below is a list of acceptable mechanisms:

- a) Any approved security function defined in Annex C;
- b) A secure element as some tamper resistant physical mechanism;
- c) Trusted platform module per the requirements of the Standard for Information technology – Trusted Platform Module Library, ISO/IEC 11889 ref. [11].

B1.2 Mechanisms can be validated through a compliance program to demonstrate correct implementation.

NOTE: An example of compliance is the FIPS 140 Cryptographic Algorithm Validation Program.

ANNEX C (INFORMATIVE)

C1 Requirements for Security Functions

C1.1 Below is a list of acceptable security functions:

- a) ISO/IEC 9796 (all parts), Information technology – Security techniques – Digital signature scheme giving message recovery, ref. [12];
- b) ISO/IEC 9797 (all parts), Information technology – Security techniques – Message Authentication Codes (MACs), ref. [13];
- c) ISO/IEC 9798 (all parts), Information technology – Security techniques – Entity authentication, ref. [14];
- d) ISO/IEC 10118 (all parts), Information technology – Security techniques – Hash-functions, ref. [15];
- e) ISO/IEC 11770 (all parts), Information technology – Security techniques – Key management, ref. [16];
- f) ISO/IEC 14888 (all parts), Information technology – Security techniques – Digital signatures with appendix, ref. [17];
- g) ISO/IEC 15946 (all parts), Information technology – Security techniques – Cryptographic techniques based on elliptic curves, ref. [18];
- h) ISO/IEC 18033 (all parts), Information technology – Security techniques – Encryption algorithms, ref. [19];
- i) ISO/IEC 19772 (all parts), Information technology – Security techniques – Authenticated encryption, ref. [20];
- j) SP 800-140C, Annex A: Approved Security Functions, ref. [22];
- k) SP 800-140D, Annex D: Approved Key Establishment Techniques, ref. [23].

C1.2 All implemented security functions can be assessed to demonstrate that they conform to the applicable standard(s) listed under [C1.1](#).

NOTE: An example of compliance is the FIPS 140 Cryptographic Algorithm Validation Program.

C1.3 Algorithm choices not covered in [C1.1](#) are to be identified and validated as part of Section [12](#), Vendor Product Risk Management Process

ANNEX D (INFORMATIVE)

A brief introduction to penetration testing and some related concepts follows.

Penetration testing is often confused with hacking, but there is a substantial difference that novices have to understand, while hacking is exploratory and unstructured, penetration testing is based on scientific and structured methods that include documenting each phase of testing and the results obtained. Penetration testing is also very different from vulnerability scanning in that scanning simply looks across the surface for vulnerabilities while penetration testing looks to see if vulnerabilities can be exploited to gain data or deeper penetration into a network.

There are a few types of penetration testing commonly referred to as White Box, Black Box and Grey Box testing. The primary difference in these types of tests is knowledge. With White Box testing, the tester has full access to source code, architecture documentation, etc. and can use that information to analyze the code itself, understand the application's behavior more completely, and create more purposeful testing scenarios. In contrast to this, Black Box testers have no information about what they are testing, which in theory simulates how an actual hacker would approach the exercise. As the name implies, Grey Box testing lies between these two extremes and simulates how a hacker with long term access to a system or some underlying information would act.

This standard is based around a White Box testing methodology where as much knowledge as is available is provided. However, since third party source code will not always be available, there may be a need for Grey Box testing in places; those areas should accordingly be part of your risk assessment process. Black Box testing would not be sufficient to meet the requirements of this standard.

Sources for Penetration Testing Methodologies and Scope:

- a) NIST SP 800-115, Technical Guide to Information Security Testing and Assessment (<https://csrc.nist.gov/publications/detail/sp/800-115/final>) – published 09/2008
- b) PCI Data Security Standard (PCI DSS) (https://www.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf) – published 09/2017
- c) Penetration Testing Execution Standard (http://www.pentest-standard.org/index.php/Main_Page) – published 4/2012
- d) Open Source Security Testing Methodology Manual (“OSSTMM”) (<http://www.isecom.org/research/>) – published 12/2010
- e) The OWASP Foundation publishes several testing guides on their site for IoT, Mobile, and Cloud (https://www.owasp.org/index.php/Main_Page)
- f) ANSI X9.111-2018, Penetration Testing Within The Financial Services Industry (<https://webstore.ansi.org/standards/ascx9/ansix91112018>)



333 Pfingsten Road
Northbrook, Illinois 60062–2096
847.272.8800

For other locations in the UL family of companies,
please visit [UL.com/contact](https://www.ul.com/contact)